

Threat Modeling dan Analisis Kerentanan Awal: Sistem BPKB-IPB (Laravel Baseline)

1. Pendahuluan dan Deskripsi Arsitektur Sistem

Sistem BPKB-IPB merupakan platform manajemen aset dan transaksi yang dibangun di atas ekosistem PHP modern menggunakan framework Laravel. Berdasarkan audit arsitektur pada baseline sistem, infrastruktur ini dirancang untuk menangani data transaksi sensitif dengan komponen teknis sebagai berikut:

- a. **Framework Utama:** Laravel, yang berfungsi sebagai *core engine* untuk routing, middleware, dan manajemen *request*.
- b. **Pustaka Autentikasi:** Laravel Breeze, digunakan sebagai gerbang utama akses pengguna (login/registrasi).
- c. **Manajemen Otorisasi:** Spatie Laravel Permission, mengimplementasikan *Role-Based Access Control* (RBAC) untuk granulasi hak akses.
- d. **Tech Stack Database:** PostgreSQL atau MySQL, sebagai media penyimpanan relasional untuk data proyek, transaksi, dan *audit logs*.
- e. **Komponen Pendukung:** Laravel-Excel untuk fungsi *data ingestion* (import/export) dan OpenSSL untuk operasi kriptografi dasar.

2. Identifikasi Aset Kritis dan Vektor Serangan

Audit teknis mengidentifikasi empat aset utama yang memiliki profil risiko tinggi jika tidak dilakukan penguatan (*hardening*) sistem secara menyeluruh:

Aset Kritis	Deskripsi Kerentanan
Autentikasi	Penggunaan Laravel Breeze tanpa konfigurasi <i>rate limiting</i> dan MFA tambahan rentan terhadap eksploitasi kredensial.
Audit Logs	Penyimpanan riwayat aktivitas dalam database yang masih bersifat <i>plaintext</i> , berisiko pada kebocoran jejak audit.
Laporan Bulanan	Dokumen output transaksi BPKB yang tidak memiliki mekanisme validasi integritas, rentan terhadap manipulasi pasca-generasi.
Saluran Komunikasi	Transmisi data antara klien dan server yang terancam oleh intersepsi data jika protokol enkripsi pada layer transport tidak optimal.

Keempat aset ini merupakan target utama serangan karena memegang peranan krusial dalam menjamin validitas kepemilikan kendaraan dan histori transaksi. Kegagalan perlindungan pada aset ini akan menyebabkan runtuhnya aspek kerahasiaan dan integritas data sistem.

3. Analisis Ancaman

Berikut adalah pemetaan ancaman terhadap aset kritis sistem BPKB-IPB:

Aset	Kategori Ancaman	Potensi Dampak	Tingkat Risiko
Autentikasi	Spoofing	Penyerang mengambil alih identitas pengguna sah melalui serangan <i>automated</i> .	High
Laporan Bulanan	Tampering	Modifikasi ilegal pada data status BPKB dalam laporan digital.	High
Laporan Bulanan	Repudiation	Penyangkalan transaksi oleh pihak terkait karena ketiadaan bukti digital yang kuat.	High
Audit Logs	Information Disclosure	Kebocoran data sensitif aktivitas sistem dari database dalam format yang mudah dibaca.	Medium
Saluran Komunikasi	Denial of Service	Gangguan pada ketersediaan jalur komunikasi yang melumpuhkan operasional sistem.	Medium
Manajemen Akses	Elevation of Privilege	Pengguna mendapatkan akses ke fungsi sensitif seperti <i>import-project</i> tanpa izin sah.	High

4. Analisis Kerentanan Mendalam

4.1 Kerentanan Autentikasi dan Saluran Komunikasi

Implementasi standar Laravel Breeze tanpa modifikasi keamanan lanjut menciptakan celah bagi serangan *Brute Force*. Tanpa proteksi pada level aplikasi, penyerang dapat melakukan ribuan percobaan login secara simultan. Selain itu, ketiadaan enkripsi end-to-end pada saluran komunikasi memungkinkan terjadinya serangan *Man-in-the-Middle (MitM)*, di mana informasi sensitif dapat disadap selama transmisi.

4.2 Masalah Integritas: Audit Logs dan Laporan Bulanan

- a. **Information Disclosure (Audit Logs):** Penyimpanan log dalam format teks biasa di database merupakan kerentanan sistemik. Jika terjadi kompromi pada database, penyerang dapat memetakan seluruh pola aktivitas administratif dan teknis sistem.
- b. **Non-repudiation (Laporan Bulanan):** Laporan yang dihasilkan tidak memiliki ikatan kriptografis yang menjamin integritasnya. Hal ini memungkinkan pengguna atau pihak eksternal memodifikasi dokumen tanpa terdeteksi, yang secara hukum memicu potensi penyangkalan atas transaksi yang telah terjadi.

5. Rekomendasi Strategi Mitigasi Teknis

5.1 Pengamanan Data Terenkripsi (AES-256-CBC)

Untuk melindungi *Audit Logs*, implementasi enkripsi simetris wajib mengikuti standar berikut:

- a. **Algoritma & Mode:** Gunakan AES-256 dalam mode *Cipher Block Chaining* (CBC).
- b. **Implementasi:** Gunakan fungsi `openssl_encrypt` dengan *Initialization Vector* (IV) yang **wajib dihasilkan secara acak (*randomly generated*)** dan unik untuk setiap entri log guna mencegah serangan *pattern recognition*.
- c. **Penyimpanan & Integritas:** Data terenkripsi harus disimpan dalam format **Base64** untuk menjamin kompatibilitas database. Tambahkan **HMAC (*Hash-based Message Authentication Code*)** untuk memverifikasi bahwa data tidak dimodifikasi dalam penyimpanan.
- d. **Manajemen Kunci:** Implementasikan **Key Rotation** secara berkala dan sangat direkomendasikan penggunaan **HSM (*Hardware Security Module*)** untuk lingkungan produksi tinggi.

5.2 Implementasi Tanda Tangan Digital (RSA & SHA-256)

Untuk menjamin *Integrity*, *Authentication*, dan *Non-repudiation* pada *Laporan Bulanan*, terapkan skema sesuai standar **Public-Key Cryptography Standards (PKCS)** dari RSA Laboratories:

- a. **Key Generation:** Gunakan panjang kunci RSA minimal **2048-bit** dengan representasi kunci dalam format **ASN.1**.
- b. **Hashing:** Lakukan proses hashing pada dokumen menggunakan algoritma SHA-256 untuk menghasilkan **Message Digest**.
- c. **Signing:** Enkripsi *Message Digest* menggunakan *Private Key* pengirim untuk menghasilkan tanda tangan digital.
- d. **Delivery:** Sematkan tanda tangan digital tersebut ke dalam dokumen dalam bentuk **QR Code**.
- e. **Verification:** Penerima menggunakan *Public Key* pengirim untuk melakukan dekripsi tanda tangan dan membandingkannya dengan hash dokumen saat ini guna memastikan validitas.

6. Kesimpulan dan Roadmap Keamanan

Audit awal menyimpulkan bahwa sistem BPKB-IPB memiliki risiko tinggi terhadap manipulasi data laporan dan kebocoran jejak audit akibat penggunaan konfigurasi *default framework*. Penguatan melalui implementasi kriptografi asimetris RSA 2048-bit dan enkripsi AES-256-CBC dengan HMAC merupakan kebutuhan mendesak untuk menjamin integritas sistem secara keseluruhan. **Roadmap Prioritas Implementasi:**

- a. **Prioritas 1 (Mendesak):** Implementasi Digital Signature (RSA 2048-bit/SHA-256) pada Laporan Bulanan dengan mekanisme verifikasi melalui QR Code.
- b. **Prioritas 2:** Enkripsi *Audit Logs* menggunakan AES-256-CBC dengan penyimpanan format Base64 dan verifikasi integritas HMAC.
- c. **Prioritas 3:** Audit ulang seluruh rute aplikasi untuk menerapkan middleware berbasis izin spesifik (lihat-project, accept-ajuan).
- d. **Prioritas 4:** Pelaksanaan kebijakan *Key Rotation* dan evaluasi penggunaan HSM. Selalu ingat bahwa keamanan siber dimulai dari kesadaran individu. Terapkan prinsip ***Think Before Click*** dalam setiap interaksi digital. Menjadi korban atau pelaku *cybercrime* sangat tergantung dari ketelitian ujung jari Anda.